

(c) Narrativa explicativa – Marco GQM + PRAGMATIC aplicado a indicadores SOC

2

Medir por medir es uno de los deportes favoritos de nuestra era. La buena noticia es que GQM, combinado con PRAGMATIC, nos obliga a hacer algo mucho más incómodo pero infinitamente más útil: preguntarnos para qué queremos cada número.

GQM pone orden en el caos: empezamos por el objetivo (Goal), formulamos preguntas que realmente importan (Question) y solo entonces definimos las métricas (Metric). El resultado es que cada indicador de SOC 2, ENS o NIS2 deja de ser un número solitario y se convierte en la respuesta a una pregunta concreta sobre gobernanza, riesgo, seguridad o resiliencia.

PRAGMATIC, por su parte, nos protege del fetichismo de las métricas. Una cifra puede ser impecable desde el punto de vista técnico y completamente inútil para la dirección. Evaluar cada métrica según si es predictiva, relevante, accionable, genuina, significativa, precisa, oportuna, independiente y rentable nos obliga a descartar aquellas que dan más trabajo que claridad.

En este marco, métricas como el porcentaje de activos críticos con análisis de riesgo actualizado, el tiempo medio de detección de incidentes o el porcentaje de cuentas con MFA pasan a ser algo más que indicadores de compliance: son termómetros de gobernanza y salud sistémica. Su fuerza reside en que conectan el lenguaje de los logs con el lenguaje del Consejo.

El resultado final es un conjunto de métricas que no solo sirven para rellenar cuadros de mando, sino para tomar decisiones difíciles: dónde invertir, qué priorizar, qué riesgos aceptar y cuáles son ya indefendibles. Si una métrica no supera el examen PRAGMATIC, quizás no merezca un hueco en la agenda del comité.